بِسْمِ اللّٰهِ الرَّحْمٰنِ الرَّحِيْمِ

اَلْحَمْدُ لِلّٰهِ رَبِّ الْعَالَمِيْنَ

وَالصَّلٰوةُ وَالسَّلَامُ عَلٰى خَاتَمِ النَّبِيِّيْنَ

Course content

Textbook:
"Computer Security Principles and Practice", Fourth Edition by:
William Stallings and Lawrie Brown"

Reference:
Cryptography & Network Security by Behrouz A. Forouzan

Course Sections:
1. Network Security
2. System Security
3. Security Mechanisms

Computer Security: Principles and Practice

Fourth Edition

By: William Stallings and Lawrie Brown

slides: slightly modified from the book authors'

Chapter 1
Introducion

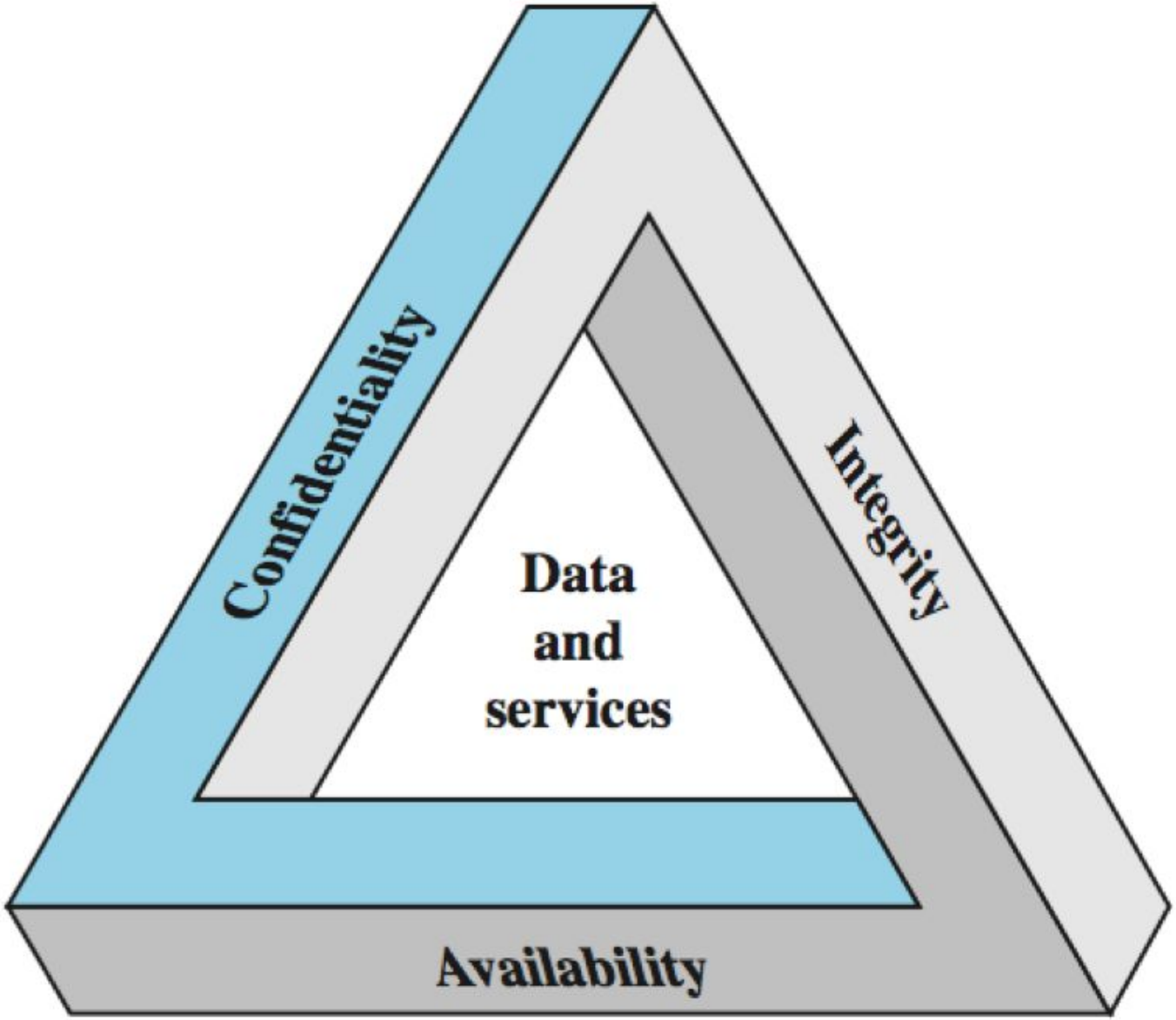
Standards bodies

NIST : National Institute of Standards and Technology.
US government agency that develops and promotes standards

FIPS: Federal Information Processing Standards
Set of publicly announced standards issued NIST

CIA

FIPS 199


Confidentiality
Integrity
Data
and
services
Availability

The NIST Internal/Interagency Report NISTIR 7298 (*Glossary of Key Information Security Terms,* May 2013) defines the term *computer security* as follows:

Measures and controls that ensure **confidentiality, integrity, and availability** of information system assets including hardware, software, firmware, and information being processed, stored, and communicated

Key Security Concepts

Confidentiality

Preserving authorized restrictions on information access and disclosure, including means for protecting **personal privacy** and proprietary information

Integrity

Guarding against improper **information modification** or destruction, including ensuring information nonrepudiation and authenticity

Availability

Ensuring timely and reliable **access** to and use of information

Additional concerns

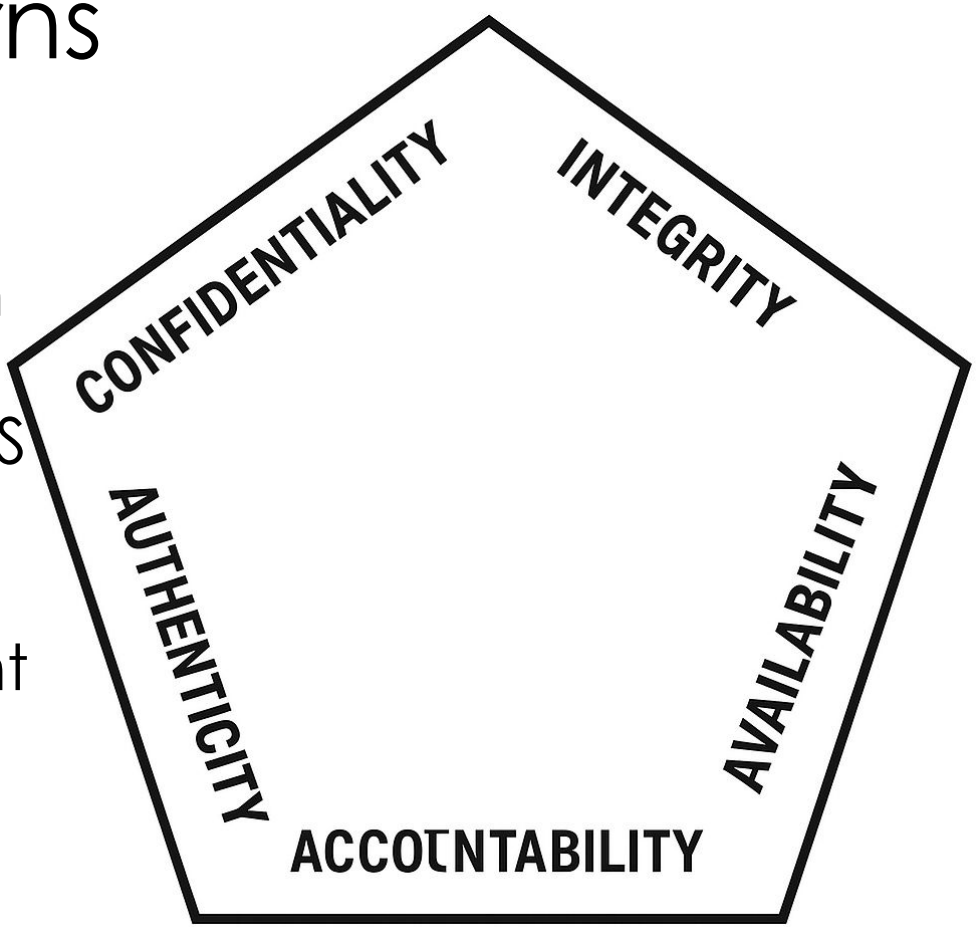
- **Authenticity**: being genuine and able to be verified

i.e entity authentication upon login

included under integrity in FIPS 199

- **Accountability**: requirement for actions of an entity to be traceable

i.e nonrepudiation, *(**repudiation** means being anonymous)*.



Accountability somewhat conflicts with confidentiality/privacy but a necessity as truly secure systems are not yet achievable. Hence, security breaches must be traceable for deterrence and forensic analysis

CIA Examples

Confidentiality:
- whatsapp chat
- phone and SD card data

Integrity:
- bank transactions
- electronic election polls (pakistan case study)
- marks sheet

Availability:
- network resources
- authentication services (e.g. RADIUS)
- critical websites (e.g. bank logins)

Authenticity: secure login

Accountability: for forensic investigation

note that each concern might be less critical for some services while more for others

Security Challenges

Problem and solution complexity
e.g. password replay attack

Threat diversity
OS vulnerabilities to physical theft

Domain diversity
Network layers, OS and DB

Continuously evolving
Cat mouse game
usually post hoc (an afterthought)

Hinders efficiency
too many passwords
financial costs
network delays (e.g. firewall capacity)

Security Model

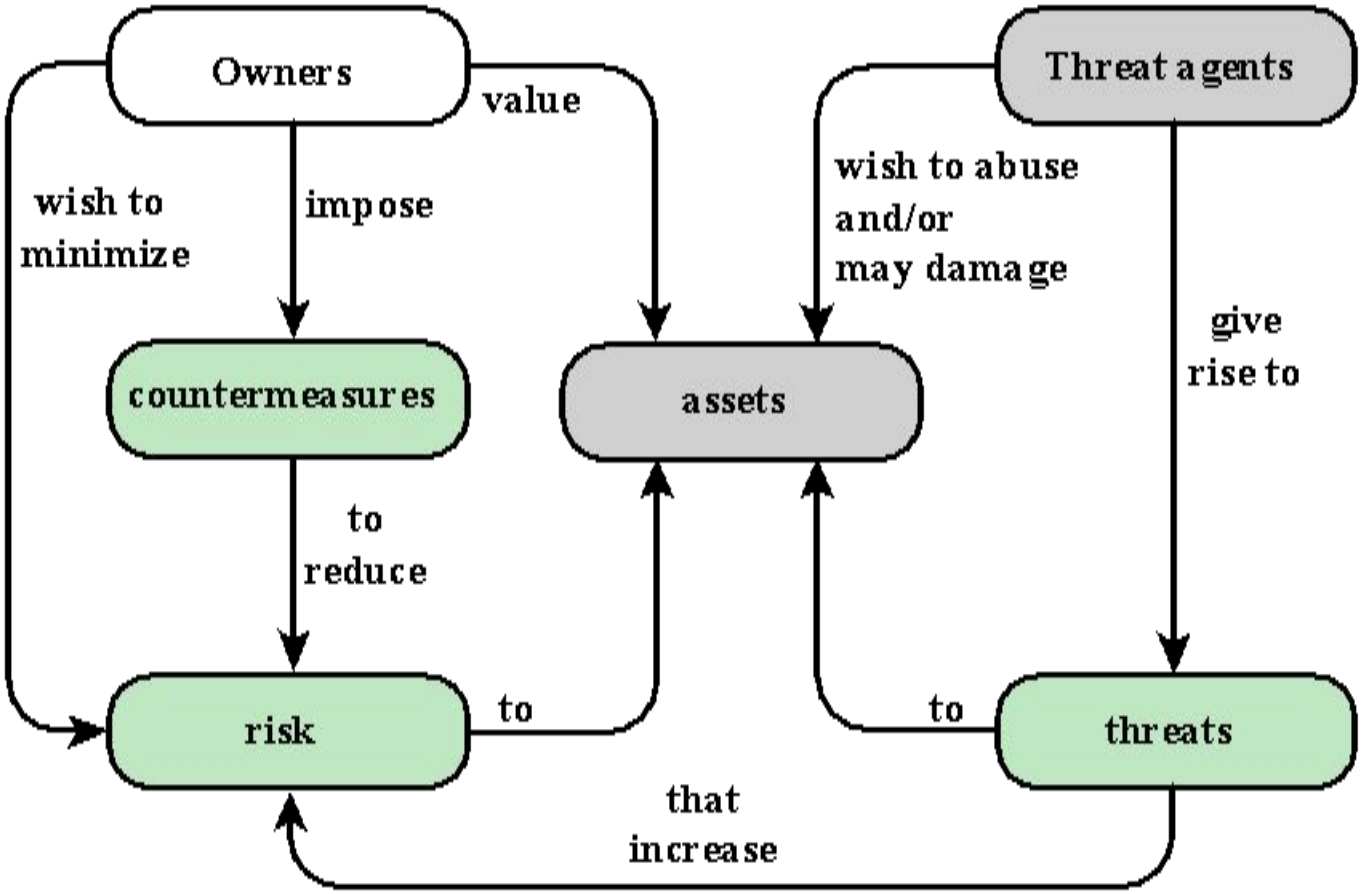


Figure 1.2 Security Concepts and Relationships

Security Terminology

- **Assets**: System resources
- **Vulnerability**: Weakness in asset that can cause security compromise (i.e. compromised CIA)
- **Adversary**: Intends to exploit vulnerability
- **Threat**: Potential of adversary exploiting the vulnerability
- **Risk**: Quantification of threat and its consequences
- **Attack**: Realization of a threat
- **Countermeasure**: techniques mitigating threat
- **Policy**: Administrative rules mitigating threat

Computer Security Terminology

System Resource (Asset): A major application, general support system, high impact program, physical plant, mission critical system, personnel, equipment, or a logically related group of systems.

Vulnerability: Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.

Adversary (threat agent): Individual, group, organization, or government that conducts or has the intent to conduct detrimental activities.

Threat: Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the Nation through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service.

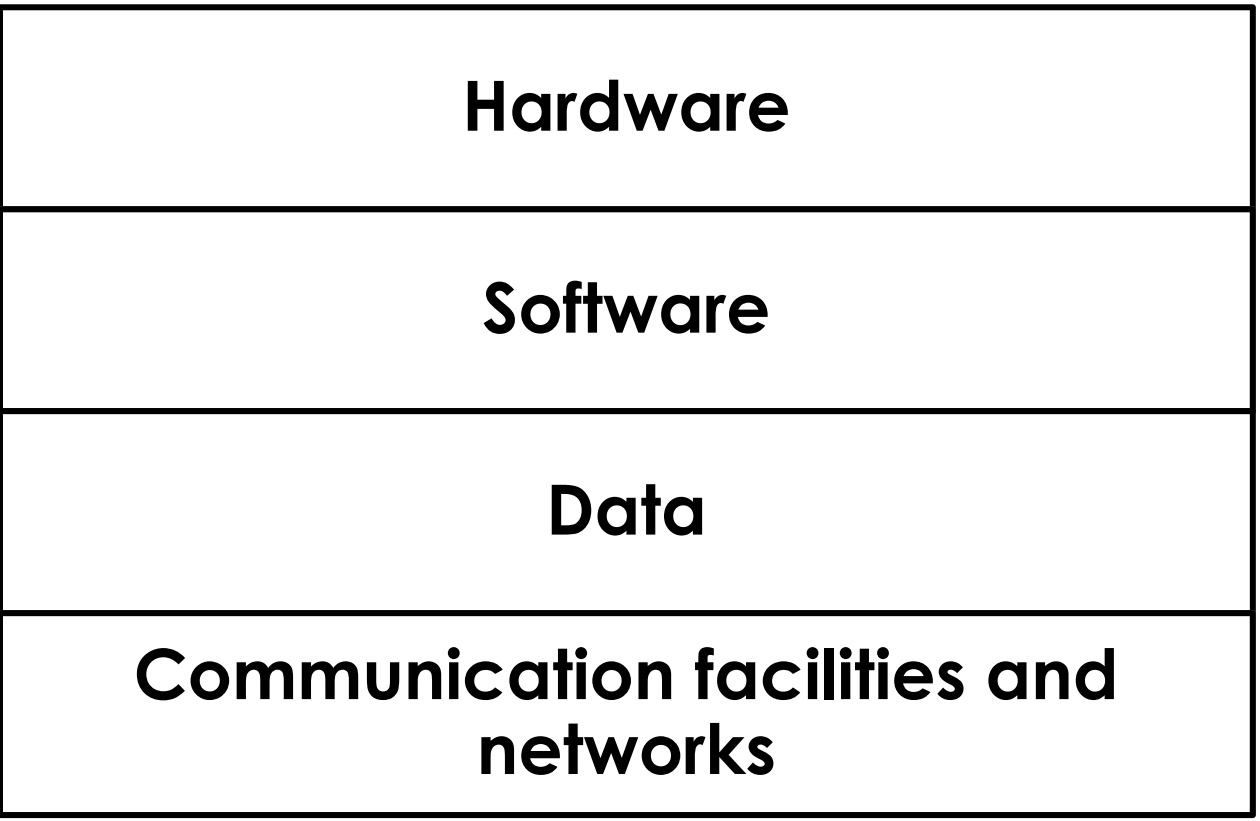
Attack: Any kind of malicious activity that attempts to collect, disrupt, deny, degrade, or destroy information system resources or the information itself.

Risk: A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of 1) the adverse impacts that would arise if the circumstance or event occurs; and 2) the likelihood of occurrence.

Countermeasure: A device or techniques that has as its objective the impairment of the operational effectiveness of undesirable or adversarial activity, or the prevention of espionage, sabotage, theft, or unauthorized access to or use of sensitive information or information systems.

Security Policy: A set of criteria for the provision of security services. It defines and constrains the activities of a data processing facility in order to maintain a condition of security for systems and data.

Assets of a Computer System i.e. System resources



Hardware: computer systems, and data processing and storage devices

Software: operating system, system utilities, and applications.

Data: files and databases (including password files)

Communication facilities and networks: communication links, routers

Vulnerability and Adversary

Vulnerability: Potential in a resource to get breached i.e to get:

- Corrupted (loss of integrity)
- Leaky (loss of confidentiality)
- Unavailable or very slow (loss of availability)

Adversary: Threat agent i.e. individual or organization with intent to carry out the attack

Vulnerability + Adversary = Threat

Threat Consequence	Threat Action (Attack)
Unauthorized Disclosure A circumstance or event whereby an entity gains access to data for which the entity is not authorized.	**Exposure:** Sensitive data are directly released to an unauthorized entity. **Interception:** An unauthorized entity directly accesses sensitive data traveling between authorized sources and destinations. **Inference:** A threat action whereby an unauthorized entity indirectly accesses sensitive data (but not necessarily the data contained in the communication) by reasoning from characteristics or byproducts of communications. **Intrusion:** An unauthorized entity gains access to sensitive data by circumventing a system's security protections.
Deception A circumstance or event that may result in an authorized entity receiving false data and believing it to be true.	**Masquerade:** An unauthorized entity gains access to a system or performs a malicious act by posing as an authorized entity. **Falsification:** False data deceive an authorized entity. **Repudiation:** An entity deceives another by falsely denying responsibility for an act.
Disruption A circumstance or event that interrupts or prevents the correct operation of system services and functions.	**Incapacitation:** Prevents or interrupts system operation by disabling a system component. **Corruption:** Undesirably alters system operation by adversely modifying system functions or data. **Obstruction:** A threat action that interrupts delivery of system services by hindering system operation.
Usurpation A circumstance or event that results in control of system services or functions by an unauthorized entity.	**Misappropriation:** An entity assumes unauthorized logical or physical control of a system resource. **Misuse:** Causes a system component to perform a function or service that is detrimental to system security.

Threats

Disclosure (compromised confidentiality):

Exposure: e.g. wiki leaks, whistleblowers (snowden, manning)

Interception: e.g. by sniffing (or even lawful)

Inference: e.g. using metadata (call records, geofencing)

Intrusion: e.g. data breaches

Deception (compromised Integrity)

Masquerade: e.g. session hijacking, password break, similar id

Falsification: e.g. illegally manipulating database records

Repudiation: Anonymity e.g. IP spoofing, VPN/PROXY, TOR

Disruption (compromised availability):

Incapacitation: e.g. OS removal

Corruption: e.g. ransomware

Obstruction: e.g. Denial of Service

Usurpation: misuse or misappropriation e.g. BOTs

Attack, Risk

Attack:

Threat being materialized

Risk

Quantified measure for extent to which an asset is threatened. Usually a function of likelihood of security compromise and scale of impact it can cause

Passive and Active Attacks

Passive Attack

Attempts to learn or make use of information from the system but does not affect system resources

Eavesdropping on, or monitoring of, transmissions

Goal of attacker is to obtain information that is being transmitted

includes:

- Release of message contents
- Traffic analysis

Active Attack

Attempts to alter system resources or affect their operation

Involve modification of the data stream or the creation of a false stream

Includes:

- Replay
- Masquerade
- Modification of messages
- Denial of service

Countermeasure

Any technique for the prevention of security breach e.g:

- Placing firewalls, IDS
- Enabling encryption
- Enabling HTTPS

Security Policies

A set of administrative rules to maintain a condition of security for systems and data.

- Disable telnet on WAN ports in broadband router
- Changing default password on installation (e.g. admin admin)
- Employee clearance forms
- Password expiry

Attack Surfaces

Network Attack Surface	Software Attack Surface	Human Attack Surface
Vulnerabilities over an enterprise network, wide-area network, or the Internet	Vulnerabilities in application, utility, or operating system code	Vulnerabilities created by personnel, such as social engineering, human error
network protocol vulnerabilities, e.g those used for a denial-of-service attack, disruption of communications links, and various intruder attacks	Web server software	Honey trapping, Phishing emails (HR test mails)